

MODELADO Y GESTIÓN DE BASE DE DATOS

TALLER_SEGURIDAD_ROLES_TRIGGERS

PRESENTA:

BERNAL GORDILLO JUAN CAMILO

NEIVA – HUILA

COORPORACIÓN UNIVERSITARIA DEL HUILA – CORHUILA

OCTUBRE DEL 2025

1.1 Introducción

En los sistemas de información que hay actualmente, especialmente en aquellos que manejan datos sensibles como lo es el sector de salud, la seguridad de la base de datos es algo muy crucial.

Con el proyecto de HospitalCare se busca realizar un esquema de seguridad que proteja la información clínica utilizando roles y disparadores (triggers), en donde cada usuario tenga un acceso que controlado y que todas las actividades críticas tengan un registro para mantener la confidencialidad, integridad y trazabilidad de los datos.

Propósito:

Este proyecto tiene como propósito garantizar la confidencialidad, integridad y trazabilidad de la información clínica que administra el sistema de HospitalCare.

Para cumplir este propósito se realizará un esquema de seguridad en base de datos que use los mecanismos de control de acceso mediante roles y auditoría automática a través de los disparadores. Esto con el objetivo de proteger los datos de los pacientes, citas y tratamientos de los accesos no autorizados, modificaciones inapropiadas o pérdidas de la información, asegurando que el sistema sea confiable.

Alcance:

El esquema de seguridad busca cubrir los siguientes aspectos:

- Controlar accesos definiendo roles específicos (administrador, médico, recepcionista y auditor), cada uno tienen permisos según sus

responsabilidades dentro del sistema, asegurando así que cada rol pueda ejecutar solo las acciones que le corresponden.

- Hacer un registro automático de las operaciones realizadas (insert, update, delete) sobre las tablas, mediante la creación de disparadores que permitan mantener un seguimiento de lo hecho por cada usuario.
- Integrar triggers que no permitan operaciones indebidas para garantizar coherencia y consistencia de la información almacenada.

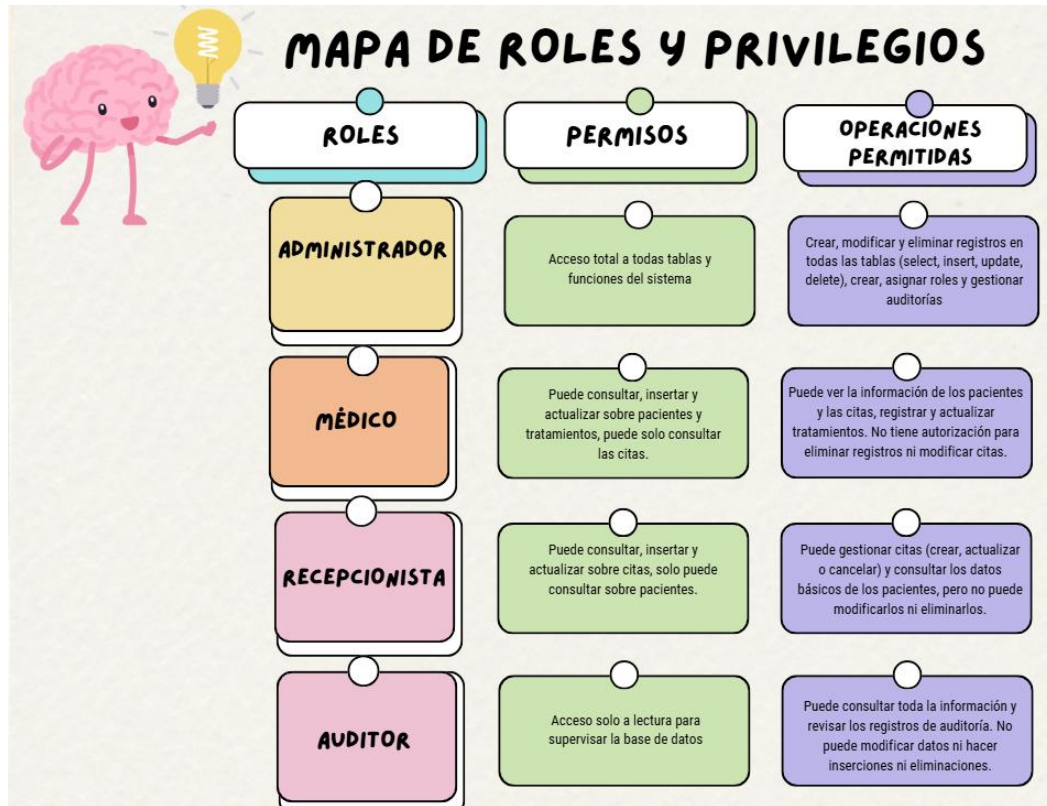
Glosario:

- **Rol:** Son unos privilegios que se le dan a un usuario en una base de datos, define en sí que operaciones puede realizar cada uno.
- **Privilegio:** Es un permiso que se da a un usuario o rol lo que le permite realizar acciones como insert, delete, update o select sobre una tabla.
- **Trigger:** Es un procedimiento que se acciona automáticamente en respuesta a eventos que suceden en una tabla, se usa para la auditoría o validación de los datos.
- **Auditoría:** Es el registro de las acciones que se hacen sobre los datos, señalando quien la realizó, cuando y sobre que información, con el objetivo de garantizar la trazabilidad.
- **Confidencialidad:** Es un principio de seguridad que busca prevenir los accesos no autorizados a la información importante.

- **Integridad:** Es una propiedad que asegura que los datos sean correctos y coherentes, evitando modificaciones no autorizadas o pérdida de la información.
- **Trazabilidad:** Es la capacidad que tiene el sistema para seguir todas las operaciones realizadas sobre los datos, reconociendo el responsable, la fecha y acción.
- **Validación:** Proceso de verificación que impide registrar información inconsistente a las reglas establecidas en la base de datos.
- **Usuario:** Persona que interactúa con la base de datos mediante un rol que se le asigna con restricciones de acceso.
- **Esquema de seguridad:** Son las configuraciones, roles, privilegios y triggers que se crean para proteger la base de datos y garantizar seguridad.

1.2 Diseño lógico de seguridad

Mapa de roles y privilegios:

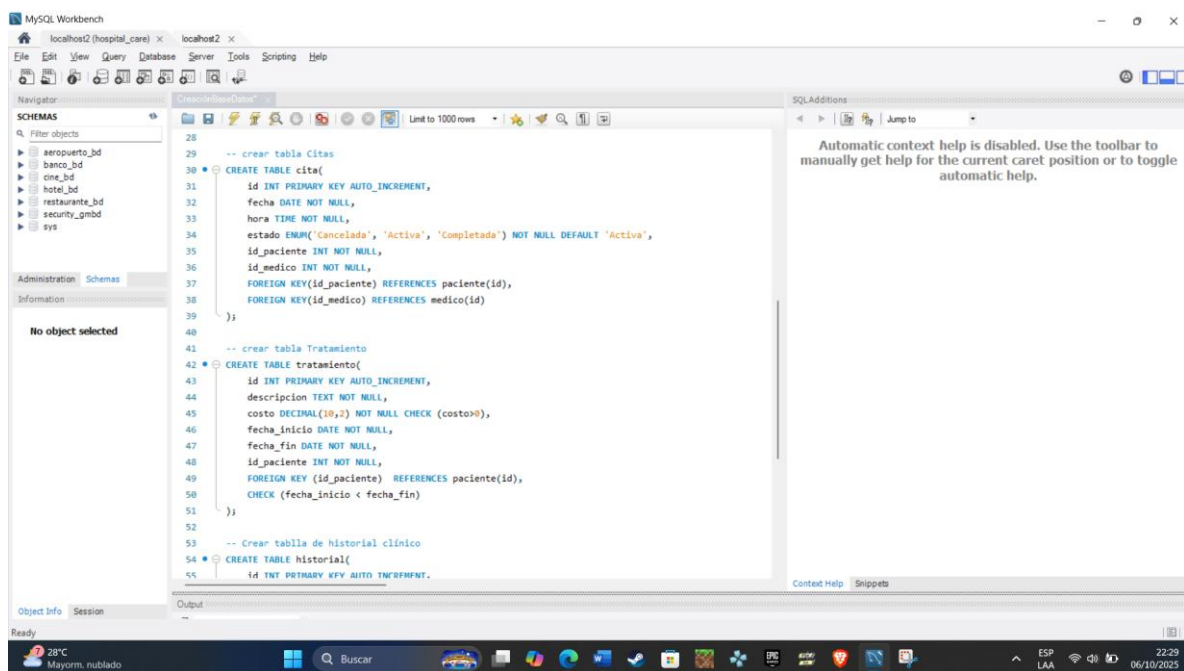
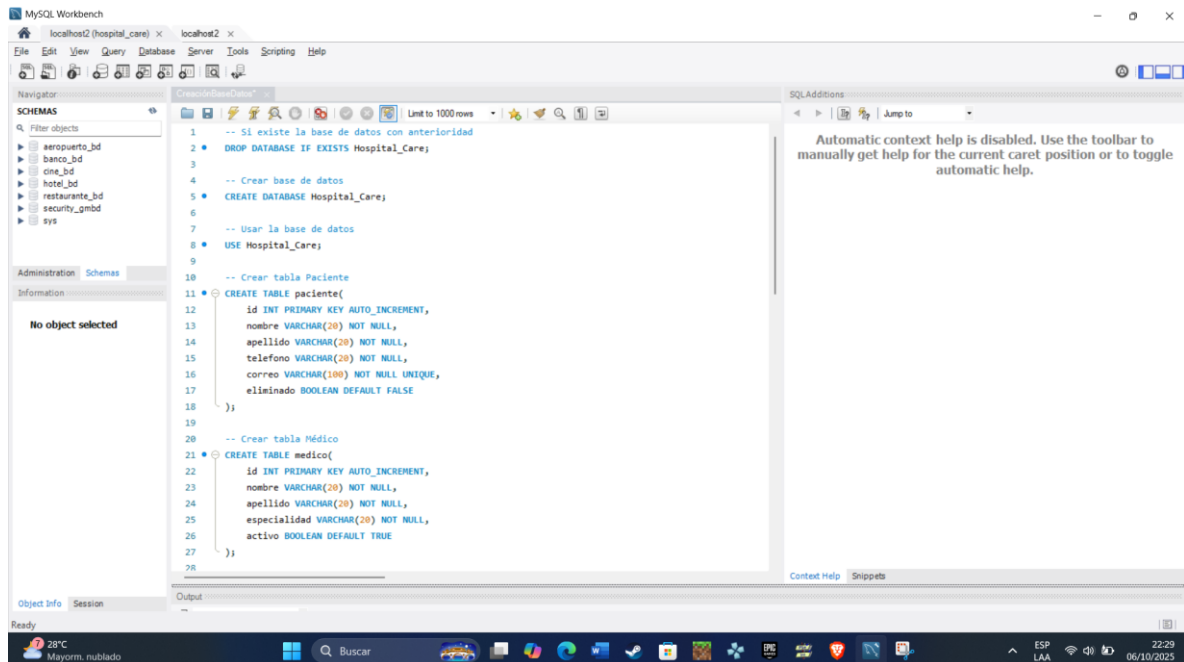


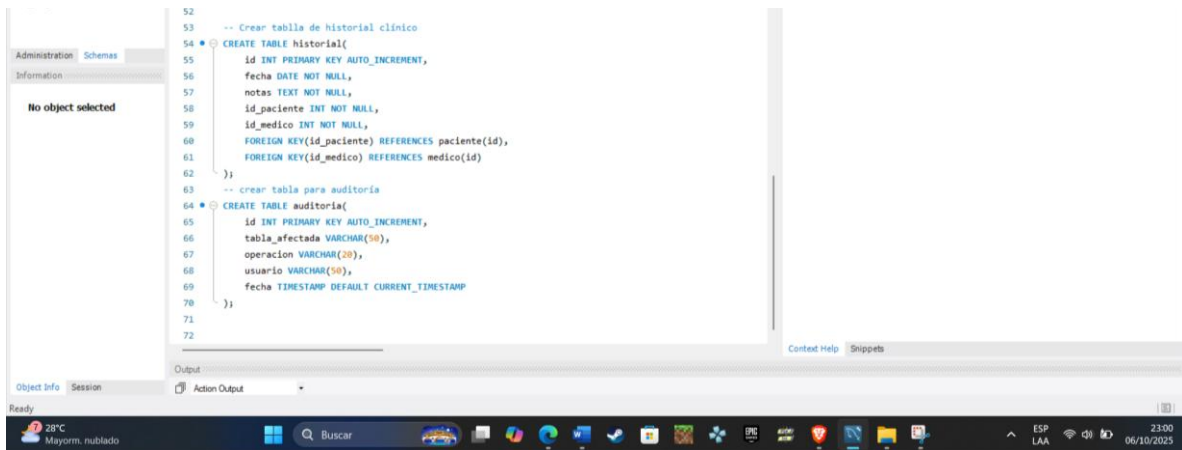
Determinar disparadores:

DISPARADORES NECESARIOS		
Trigger	Propósito	Tablas afectadas
Auditoría	Registrar de forma automática las operaciones de insert, delete y update que se realicen, con la información del usuario y la fecha	Pacientes, citas y tratamientos
Soft-delete	Señalar un registro como eliminado en lugar de borrarlo físicamente	Pacientes
Validación de negocio	Impedir que se eliminen pacientes con citas pendientes	Pacientes y citas

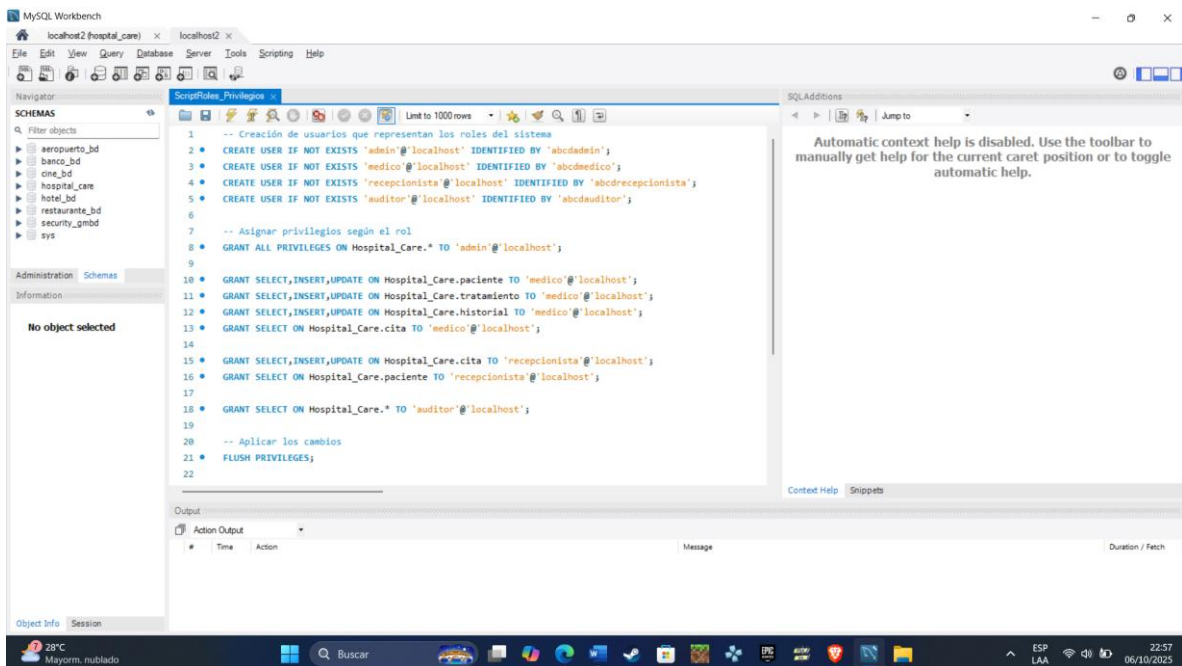
1.3 Implementación en MySQL

- Crear tablas (paciente, medico, cita, tratamiento, historial), y una tabla adicional llamada auditoria que nos va a servir para el control con el trigger.

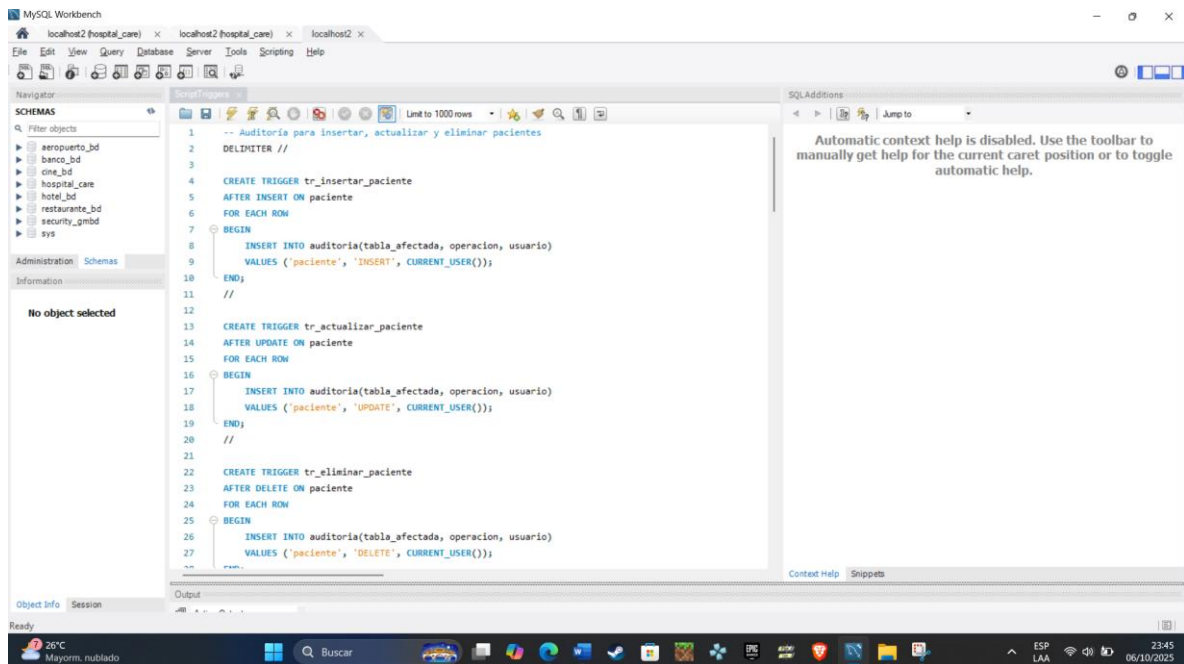




- Crear roles con privilegios.

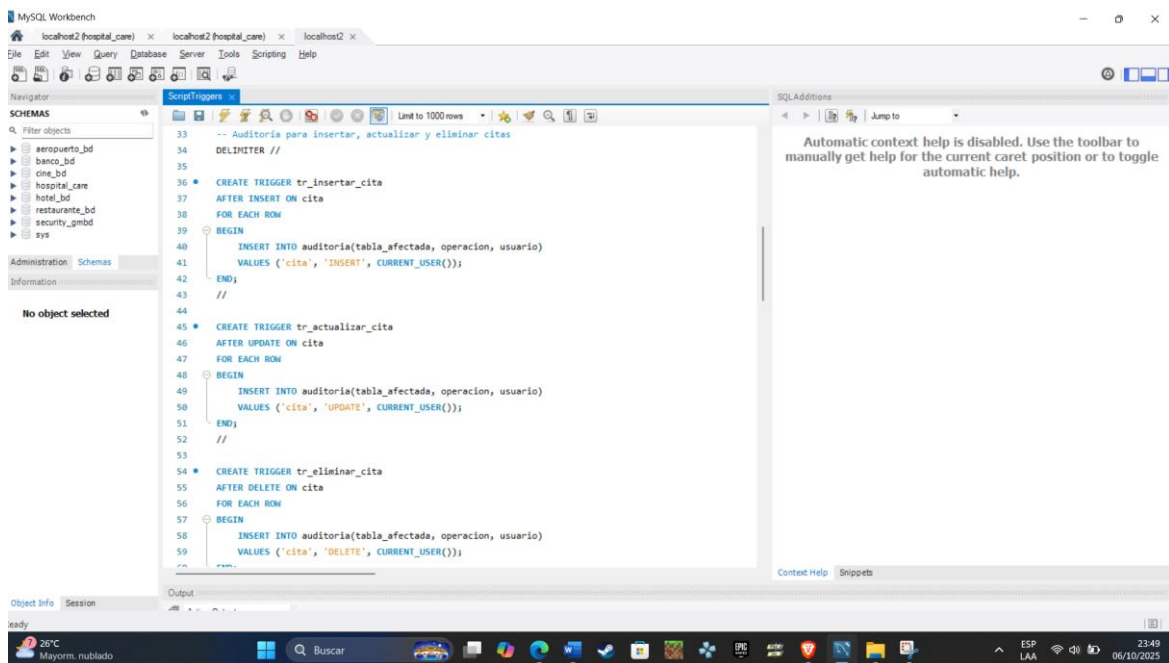


- Auditoría en la tabla paciente (Insert, Update, Delete)



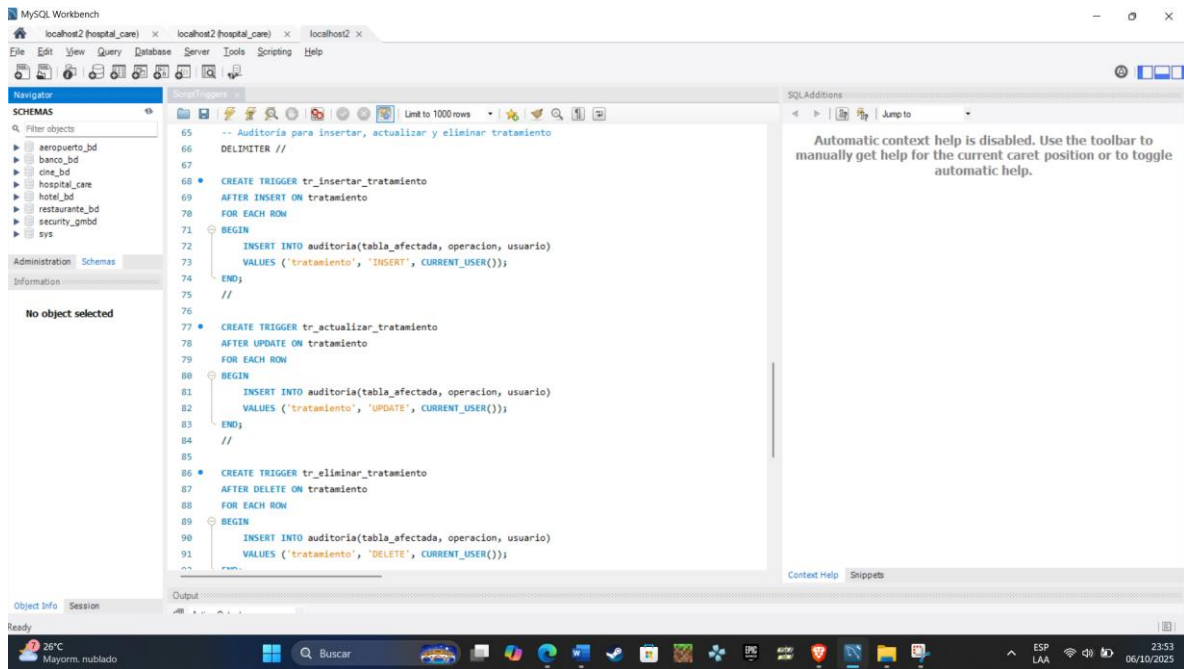
```
26     INSERT INTO auditoria(tabla_afectada, operacion, usuario)
27     VALUES ('paciente', 'DELETE', CURRENT_USER());
28 END;
29 //
30 DELIMITER ;
```

- Auditoría en la tabla cita (Insert, Update, Delete)



```
57 BEGIN
58     INSERT INTO auditoria(tabla_afectada, operacion, usuario)
59     VALUES ('cita', 'DELETE', CURRENT_USER());
60 END;
61 //
62 DELIMITER ;
```

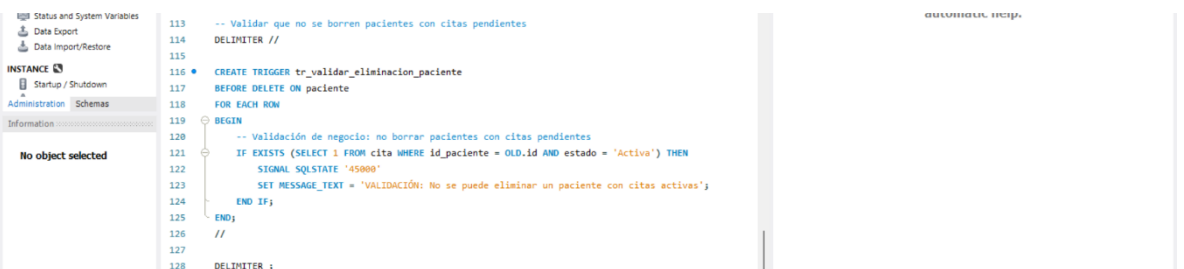
- Auditoría en la tabla tratamiento (Insert, Update, Delete)



- Trigger soft-delete para marcar como eliminado en lugar de borrar.

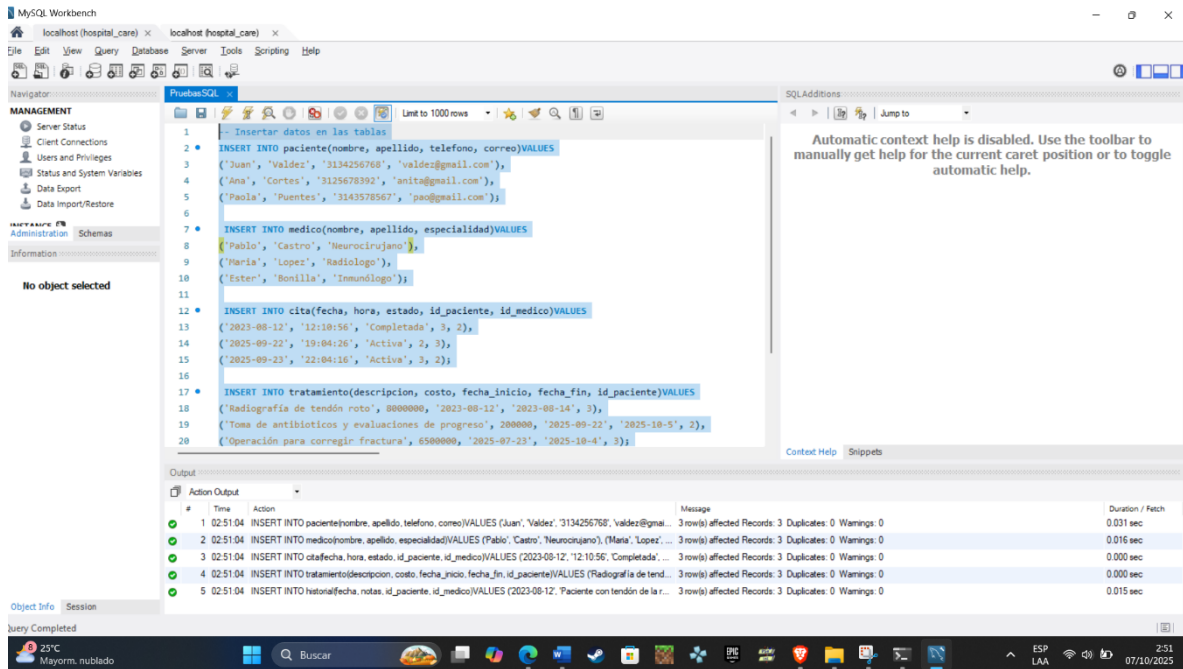


- Trigger para validar que no se borren pacientes con citas pendientes



1.4 Pruebas

- Inserción de datos



MySQL Workbench interface showing the execution of SQL queries to insert data into a database. The queries are executed in the SQL editor, and the results are displayed in the Output window.

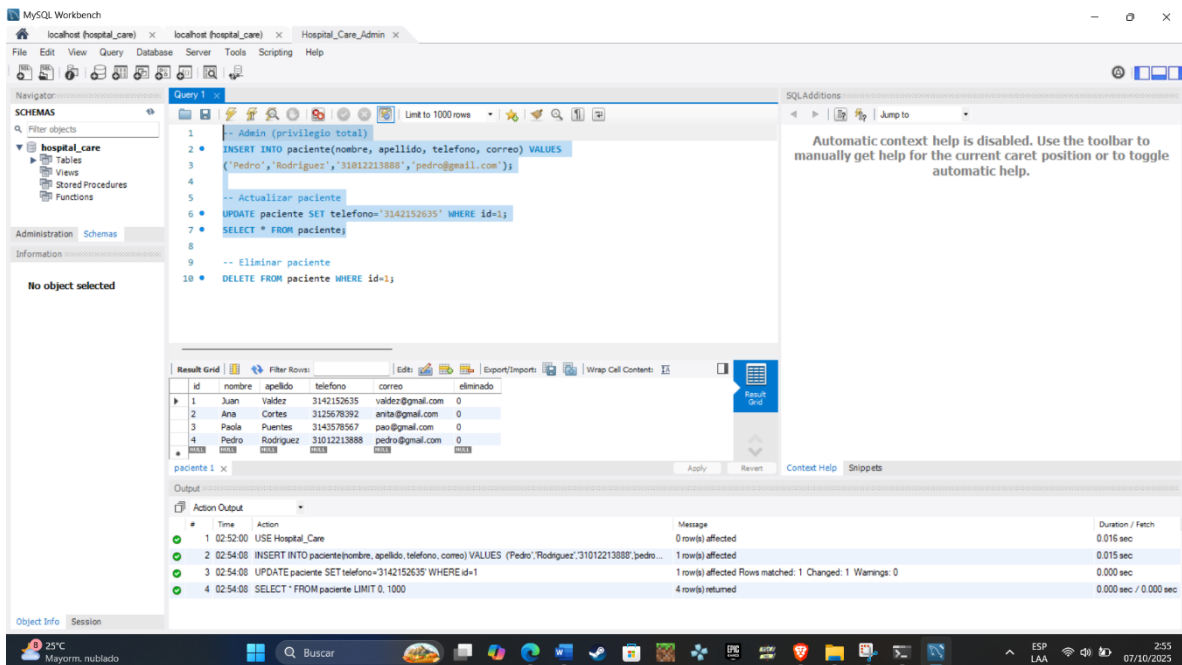
Queries:

```
1 -- Insertar datos en las tablas
2 INSERT INTO paciente(nombre, apellido, telefono, correo)VALUES
3 ('Juan', 'Valdez', '3134256768', 'valdez@gmail.com'),
4 ('Ana', 'Cortes', '3125678392', 'anita@gmail.com'),
5 ('Paola', 'Puentes', '3143578567', 'pao@gmail.com');
6
7 INSERT INTO medico(nombre, apellido, especialidad)VALUES
8 ('Pablo', 'Castro', 'Neurocirujano'),
9 ('Maria', 'Lopez', 'Radiologo'),
10 ('Ester', 'Bonilla', 'Inmunologo');
11
12 INSERT INTO cita(fecha, hora, estado, id_paciente, id_medico)VALUES
13 ('2023-08-12', '12:10:56', 'Completada', 3, 2),
14 ('2025-09-22', '19:04:26', 'Active', 2, 3),
15 ('2025-09-23', '22:04:16', 'Active', 3, 2);
16
17 INSERT INTO tratamiento(descripcion, costo, fecha_inicio, fecha_fin, id_paciente)VALUES
18 ('Radiografia de tendón roto', 8000000, '2023-08-12', '2023-08-14', 3),
19 ('Toma de antibióticos y evaluaciones de progreso', 200000, '2025-09-22', '2025-10-5', 2),
20 ('Operación para corregir fractura', 6500000, '2025-07-23', '2025-10-4', 3);
```

Output:

#	Time	Action	Message	Duration / Fetch
1	02:51:04	INSERT INTO paciente(nombre, apellido, telefono, correo)VALUES ('Juan', 'Valdez', '3134256768', 'valdez@gmail.com')	3 row(s) affected Records: 3 Duplicates: 0 Warnings: 0	0.031 sec
2	02:51:04	INSERT INTO medico(nombre, apellido, especialidad)VALUES ('Pablo', 'Castro', 'Neurocirujano'), ('Maria', 'Lopez', 'Radiologo'), ('Ester', 'Bonilla', 'Inmunologo')	3 row(s) affected Records: 3 Duplicates: 0 Warnings: 0	0.016 sec
3	02:51:04	INSERT INTO cita(fecha, hora, estado, id_paciente, id_medico)VALUES ('2023-08-12', '12:10:56', 'Completada', 3, 2), ('2025-09-22', '19:04:26', 'Active', 2, 3), ('2025-09-23', '22:04:16', 'Active', 3, 2)	3 row(s) affected Records: 3 Duplicates: 0 Warnings: 0	0.000 sec
4	02:51:04	INSERT INTO tratamiento(descripcion, costo, fecha_inicio, fecha_fin, id_paciente)VALUES ('Radiografia de tendón roto', 8000000, '2023-08-12', '2023-08-14', 3), ('Toma de antibióticos y evaluaciones de progreso', 200000, '2025-09-22', '2025-10-5', 2), ('Operación para corregir fractura', 6500000, '2025-07-23', '2025-10-4', 3)	3 row(s) affected Records: 3 Duplicates: 0 Warnings: 0	0.000 sec
5	02:51:04	INSERT INTO tratamiento(descripcion, costo, fecha_inicio, fecha_fin, id_paciente)VALUES ('Radiografia de tendón roto', 8000000, '2023-08-12', '2023-08-14', 3), ('Toma de antibióticos y evaluaciones de progreso', 200000, '2025-09-22', '2025-10-5', 2), ('Operación para corregir fractura', 6500000, '2025-07-23', '2025-10-4', 3)	3 row(s) affected Records: 3 Duplicates: 0 Warnings: 0	0.015 sec

- Operaciones con roles (admin que tiene privilegio total)



MySQL Workbench interface showing the execution of SQL queries to manage roles and data. The queries are executed in the SQL editor, and the results are displayed in the Output window.

Queries:

```
1 -- Admin (privilegio total)
2 INSERT INTO paciente(nombre, apellido, telefono, correo) VALUES
3 ('Pedro', 'Rodriguez', '31012213888', 'pedro@gmail.com');
4
5 -- Actualizar paciente
6 UPDATE paciente SET telefono='3142152635' WHERE id=1;
7 SELECT * FROM paciente;
8
9 -- Eliminar paciente
10 DELETE FROM paciente WHERE id=1;
```

Result Grid:

id	nombre	apellido	telefono	correo	eliminado
1	Juan	Valdez	3142152635	valdez@gmail.com	0
2	Ana	Cortes	3125678392	anita@gmail.com	0
3	Paola	Puentes	3143578567	pao@gmail.com	0
4	Pedro	Rodriguez	31012213888	pedro@gmail.com	0

Output:

#	Time	Action	Message	Duration / Fetch
1	02:52:00	USE Hospital_Care	0 row(s) affected	0.016 sec
2	02:54:00	INSERT INTO paciente(nombre, apellido, telefono, correo) VALUES ('Pedro', 'Rodriguez', '31012213888', 'pedro@gmail.com')	1 row(s) affected	0.015 sec
3	02:54:00	UPDATE paciente SET telefono='3142152635' WHERE id=1	1 row(s) affected Rows matched: 1 Changed: 1 Warnings: 0	0.000 sec
4	02:54:00	SELECT * FROM paciente LIMIT 0, 1000	4 row(s) returned	0.000 sec / 0.000 sec

MySQL Workbench

localhost (hospital_care) x localhost (hospital_care) x Hospital_Care_Admin x

File Edit View Query Database Server Tools Scripting Help

Navigator

SCHEMAS

Filter objects

hospital_care

Tables

Views

Stored Procedures

Functions

Administration Schemas

Information

No object selected

Query 1 x

Limit to 1000 rows

```

1 -- Admin (privilegio total)
2 INSERT INTO paciente(nombre, apellido, telefono, correo) VALUES
3 ('Pedro','Rodriguez','31012213888','pedro@gmail.com');
4
5 -- Actualizar paciente
6 UPDATE paciente SET telefono='3142152635' WHERE id=1;
7 SELECT * FROM paciente;
8
9 -- Eliminar paciente
10 DELETE FROM paciente WHERE id=1;
11

```

Result Grid

id	nombre	apellido	telefono	correo	eliminado
2	Ana	Cortes	3125678392	ana@gmail.com	0
3	Paola	Puentes	3143578567	pao@gmail.com	0
4	Pedro	Rodriguez	31012213888	pedro@gmail.com	0

paciente 2 x

Apply Revert Context Help Snippets

Output

Action Output

#	Time	Action	Message	Duration / Fetch
2	02:54:08	INSERT INTO paciente(nombre, apellido, telefono, correo) VALUES ('Pedro','Rodriguez','31012213888','pedro...)	1 row(s) affected	0.015 sec
3	02:54:08	UPDATE paciente SET telefono='3142152635' WHERE id=1	1 row(s) affected Rows matched: 1 Changed: 1 Warnings: 0	0.000 sec
4	02:54:08	SELECT * FROM paciente LIMIT 0, 1000	4 row(s) returned	0.000 sec / 0.000 sec
5	02:55:37	DELETE FROM paciente WHERE id=1	1 row(s) affected	0.000 sec
6	02:55:47	SELECT * FROM paciente LIMIT 0, 1000	3 row(s) returned	0.000 sec / 0.000 sec

Object Info Session

25°C Mayorm, nublado

Buscar

ESP LAA

2:55 07/10/2025

- Médico que tiene el poder de insertar, seleccionar y actualizar en tratamientos y pacientes, pero que solo puede consultar citas, y no puede eliminar pacientes.

MySQL Workbench

localhost (hospital_care) x localhost (hospital_care) x Hospital_Care_Admin x Hospital_Care_Medico x

File Edit View Query Database Server Tools Scripting Help

Navigator

MANAGEMENT

Server Status

Client Connections

Users and Privileges

Status and System Variables

Data Export

Data Import/Restore

Administration Schemas

Information

No object selected

Query 1 x

Limit to 1000 rows

```

4 SELECT * FROM cita;
5
6 -- Insertar tratamiento
7 INSERT INTO tratamiento(descripcion, costo, fecha_inicio, fecha_fin, id_paciente)
8 VALUES ('Tratamiento de hombro', 180.00, '2025-10-12', '2025-10-22', 2);
9
10 -- Insertar historial
11 INSERT INTO historial(fecha, notas, id_paciente, id_medico)
12 VALUES ('2025-10-12', 'Revisión inmunológica', 2, 3);
13
14 -- No puede eliminar paciente
15 DELETE FROM paciente WHERE id=1;

```

Result Grid

id	fecha	hora	estado	id_paciente	id_medico
1	2023-08-12	12:10:56	Completada	3	2
2	2025-09-22	19:04:26	Activa	2	3
3	2025-09-23	22:04:16	Activa	3	2

paciente 5 cita 6 x

Apply Revert Context Help Snippets

Output

Action Output

#	Time	Action	Message	Duration / Fetch
1	03:06:29	SELECT * FROM paciente LIMIT 0, 1000	3 row(s) returned	0.000 sec / 0.000 sec
2	03:06:29	SELECT * FROM cita LIMIT 0, 1000	3 row(s) returned	0.000 sec / 0.000 sec
3	03:06:29	INSERT INTO tratamiento(descripcion, costo, fecha_inicio, fecha_fin, id_paciente) VALUES (Tratamiento de homb...	1 row(s) affected	0.000 sec
4	03:06:29	INSERT INTO historial(fecha, notas, id_paciente, id_medico) VALUES (2025-10-12, 'Revisión inmunológica', 2, 3)	1 row(s) affected	0.000 sec
5	03:06:29	DELETE FROM paciente WHERE id=1	Error Code: 1142. DELETE command denied to user 'medico'@'localhost' for table 'paciente'	0.000 sec

Object Info Session

Query interrupted

1 mm de lluvia Domingo

Buscar

ESP LAA

3:06 07/10/2025

- Recepcionista que puede consultar, insertar y actualizar sobre citas, puede solo consultar los pacientes.

MySQL Workbench interface showing a query execution for a receptionist user. The query includes inserting a new appointment, updating its status to 'Cancelada', and updating a patient's email. The output shows the results of these actions.

```

1 -- Insertar cita
2 INSERT INTO cita(fecha,hora,estado,id_paciente,id_medico)
3 VALUES ('2025-10-13','09:30:00','Activa',2,1);
4
5 -- Actualizar cita
6 UPDATE cita SET estado='Cancelada' WHERE id=1;
7 SELECT * FROM cita;
8
9 -- No puede actualizar ni eliminar paciente
10 UPDATE paciente SET correo = 'benitez@gmail.com' WHERE id = 3;
11 DELETE FROM paciente WHERE id=1;
12

```

#	Time	Action	Message	Duration / Fetch
1	03:16:07	INSERT INTO cita(fecha,hora,estado,id_paciente,id_medico) VALUES (2025-10-13:'09:30:00','Activa',2,1)	1 row(s) affected	0.000 sec
2	03:16:07	UPDATE cita SET estado='Cancelada' WHERE id=1	1 row(s) affected Rows matched: 1 Changed: 1 Warnings: 0	0.016 sec
3	03:16:07	SELECT * FROM cita LIMIT 0, 1000	4 row(s) returned	0.000 sec / 0.000 sec
4	03:16:07	UPDATE paciente SET correo = 'benitez@gmail.com' WHERE id = 3	Error Code: 1142. UPDATE command denied to user 'recepcionista'@'localhost' for table 'paciente'	0.000 sec

MySQL Workbench interface showing a query execution for a receptionist user. The query includes inserting a new appointment, updating its status to 'Cancelada', and updating a patient's email. The output shows the results of these actions.

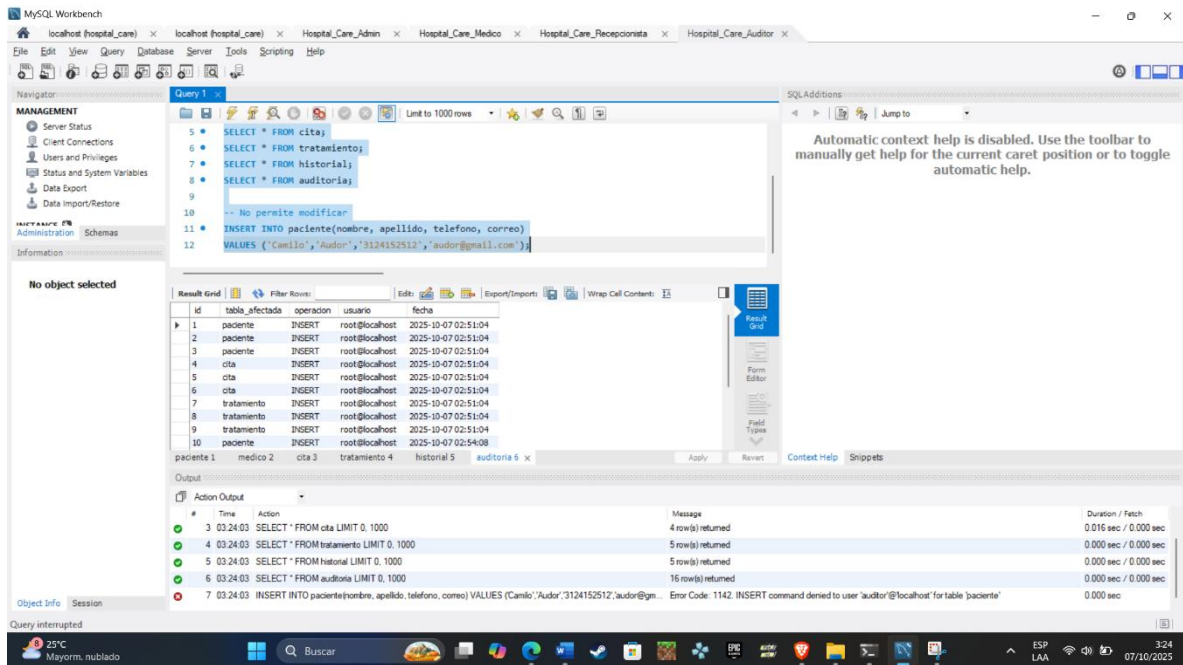
```

1 -- Recepcionista
2 -- Insertar cita
3 INSERT INTO cita(fecha,hora,estado,id_paciente,id_medico)
4 VALUES ('2025-10-13','09:30:00','Activa',2,1);
5
6 -- Actualizar cita
7 UPDATE cita SET estado='Cancelada' WHERE id=1;
8 SELECT * FROM cita;
9
10 -- No puede actualizar ni eliminar paciente
11 UPDATE paciente SET correo = 'benitez@gmail.com' WHERE id = 3;
12

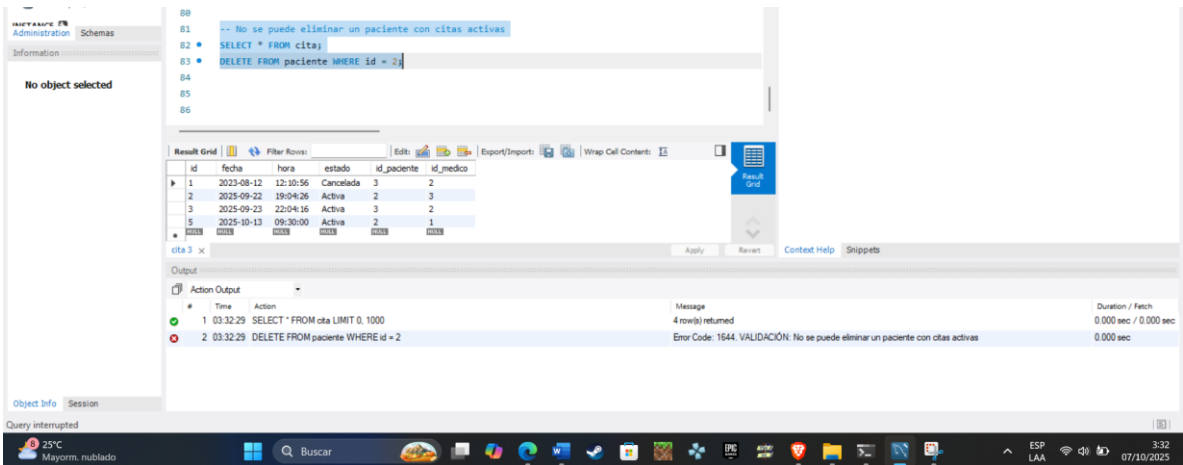
```

#	Time	Action	Message	Duration / Fetch
1	03:16:07	INSERT INTO cita(fecha,hora,estado,id_paciente,id_medico) VALUES (2025-10-13:'09:30:00','Activa',2,1)	1 row(s) affected	0.000 sec
2	03:16:07	UPDATE cita SET estado='Cancelada' WHERE id=1	1 row(s) affected Rows matched: 1 Changed: 1 Warnings: 0	0.016 sec
3	03:16:07	SELECT * FROM cita LIMIT 0, 1000	4 row(s) returned	0.000 sec / 0.000 sec
4	03:16:07	UPDATE paciente SET correo = 'benitez@gmail.com' WHERE id = 3	Error Code: 1142. UPDATE command denied to user 'recepcionista'@'localhost' for table 'paciente'	0.000 sec
5	03:20:23	SELECT * FROM paciente LIMIT 0, 1000	3 row(s) returned	0.000 sec / 0.000 sec

- Auditor que solo puede consultar los sistemas, no puede modificar nada.



- Otra prueba sería como no se puede eliminar un paciente con citas activas



- Para comprobar que los triggers funcionan se consulta la tabla auditoria

The screenshot shows the MySQL Workbench interface with a SQL query editor and a results grid. The query is as follows:

```
-- No permite modificar
76
77
78 • INSERT INTO paciente(nombre, apellido, telefono, correo)
79   VALUES ('Camilo','Aldor','3124152512','aldor@gmail.com');
80
81 -- No se puede eliminar un paciente con citas activas
82 • SELECT * FROM cita;
83 • DELETE FROM paciente WHERE id = 2;
84
85 -- Verificar Triggers
86 • SELECT * FROM auditoria;
87
```

The results grid shows the following data:

id	tabla_afectada	operacion	usuario	fecha
15	cita	INSERT	root@localhost	2025-10-07 03:16:07
16	cita	UPDATE	root@localhost	2025-10-07 03:16:07
17	cita	UPDATE	root@localhost	2025-10-07 03:37:02
18	paciente	DELETE	root@localhost	2025-10-07 03:39:05
19	paciente	INSERT	root@localhost	2025-10-07 03:42:18

The output pane shows the following messages:

#	Time	Action	Message	Duration / Fetch
11	03:42:38	SELECT id, nombre, eliminado FROM paciente WHERE id = 4 LIMIT 0, 1000	0 row(s) returned	0.000 sec / 0.000 sec
12	03:42:46	UPDATE paciente SET eliminado = TRUE WHERE id = 4	0 row(s) affected Rows matched: 0 Changed: 0 Warnings: 0	0.015 sec
13	03:42:53	SELECT id, nombre, eliminado FROM paciente WHERE eliminado = FALSE LIMIT 0, 1000	3 row(s) returned	0.000 sec / 0.000 sec
14	03:43:04	SELECT id, nombre, eliminado FROM paciente WHERE id = 4 LIMIT 0, 1000	0 row(s) returned	0.000 sec / 0.000 sec
15	03:46:39	SELECT * FROM auditoria LIMIT 0, 1000	19 row(s) returned	0.000 sec / 0.000 sec

Bibliografia

GeeksforGeeks. (2023). MySQL Trigger Example. Recuperado de <https://www.geeksforgeeks.org/mysql-triggers/>

IBM. (2024). What is data integrity?. Recuperado de <https://www.ibm.com/topics/data-integrity>

Oracle. (2023). MySQL 8.0 Reference Manual: CREATE TRIGGER Statement. MySQL Documentation. Recuperado de <https://dev.mysql.com/doc/refman/8.0/en/create-trigger.html>

Oracle. (2023). MySQL 8.0 Reference Manual: Privileges provided by MySQL. MySQL Documentation. Recuperado de <https://dev.mysql.com/doc/refman/8.0/en/privileges-provided.html>

Supabase. (2024). *Row Level Security (PostgreSQL)*. Recuperado de <https://supabase.com/docs/guides/database/postgres/row-level-security>